DOYENSEC

# Security Audit Summary

ChatGPT macOS app

Asad Mansoor, asad@cloudcontrolstudio.com, 2025-04-11T16:08:58.797Z

Prepared for: OpenAI
Prepared by: John Villamil
Date: 05/23/2024

# Executive Summary

## Overview

OpenAI engaged Doyensec to perform a security assessment of the ChatGPT macOS app project. The project commenced on 05/06/2024 and ended on 05/17/2024 requiring one (1) security researcher.

The project consisted of a manual desktop application security assessment (macOS).

Testing was conducted remotely from Doyensec's EMEA and US offices.

## Scope

Through meetings with OpenAI, the scope of the project was clearly defined. The agreed-upon assets are listed below:

- ChatGPT macOS native application

The testing took place in a production environment using the latest version of the software at the time of testing. In detail, this activity was performed on the following releases:

- ChatGPT macOS app
  - App version: 1.2024.130 (1715633188)
  - SHA1(superassistant-main.zip): `31c973c3267a869fa6256fb80dc58a4ff9e5656e`

## Scoping Restrictions

During the engagement, Doyensec encountered difficulties testing some of the functionalities of the platforms due to access issues in the ChatGPT macOS app platform. OpenAI successfully troubleshoot these issues during the first week of the engagement. Additionally, some functionalities could not be tested as they were not entirely implemented or they were not deployed to the instances used for testing.

## Findings Summary

Doyensec researchers discovered and reported four (4) vulnerabilities in the ChatGPT macOS app. While most of the issues were departures from best practices and low-severity flaws, Doyensec identified one (1) issue rated as medium that can be leveraged to compromise the confidentiality, integrity and availability of the platform.

It is important to reiterate that this report represents a snapshot of the security posture of the scope at a point in time.

Overall, the security posture of the Internet-facing APIs was found to be in line with industry best practices.

Asad Mansoor, asad@cloudcontrolstudio.com 2025-04-11T 6:06:39.797Z

# Methodology

## Overview

Doyensec treats each engagement as a fluid entity. We use a standard base of tools and techniques from which we built our own unique methodology. Our 30 years of information security experience has taught us that mixing offensive and defensive philosophies is the key for standing against threats, thus we recommend a whitebox approach combining dynamic fault injection with an in-depth study of source code to maximize the ROI on bug hunting.

During this assessment, we have employed standard testing methodologies (e.g., OWASP Testing guide recommendations) as well as custom checklists to ensure full coverage of both code and vulnerabilities classes.

## Setup Phase

OpenAI provided access to the online environments, source code archives, and binaries for the macOS application.

The following OpenAI accounts were provisioned and used to access the Search and ChatGPT macOS app platforms:

- john-doyensec-tester@c-openai.com
- savio-doyensec-tester@c-openai.com

## Tooling

When performing assessments, we combine manual security testing with state-of-the-art tools in order to improve efficiency and efficacy of our effort.

During this engagement, we used the following tools:

- Burp Suite
- Nmap
- Wireshark
- Subfinder
- Xcode
- Semgrep
- Trufflehog
- Curl, netcat and other Linux utilities

## Web Application and API Techniques

Web assessments are centered on the data sent between clients and servers. In this realm, the principle audit tool is the Burp Suite, however we also use a large set of custom scripts and extensions to perform specific audit tasks. We focus on authorization, authentication, integrity and trust. We study how data is interpreted, parsed, stored, and relayed between producers and consumers.

We subvert the client with malicious data through reflected and DOM based Cross Site Scripting and by breaking assumptions in trust. We test the server endpoints for injection style flaws including, but not limited to, SQL, template, XML, and command injection flaws. We look at each request and response pair for potential Cross Site Request Forgery and race conditions. We study the application for subtle logic issues, whether they are authorization bypasses or insecure object references. Session storage and retrieval is scrutinized and user separation is thoroughly tested.

Web security is not limited to popular bug titles. Doyensec researchers understand the goals and needs of the application to find ways of breaking the assumed control flow

## Desktop and Server Applications

Doyensec has extensive experience finding flaws in thick clients, standalone binaries, and server daemons. We write customized tools to map out control flow and study an application's behavior and internals. Mapping out attack surface, whether local or remote, is paramount to a successful engagement. Doyensec studies the application's ecosystem, looking for potential downfalls and misconceptions.

Asad Mansoor, asad@cloudcontrolstudio.com 2025-04-11 16:08:50 +0000Z

Fuzzing and instrumentation are important parts of the SDLC which we use to test an application's response to untrusted data. Doyensec has a mature, automated, and flexible fuzzing framework which will be customized to meet the needs of the target and detect its behavior to malicious input over the course of days and weeks.

We take apart the application looking for privacy leaks and secrets. Storage, transmission, and protection of user information is critical. Server side handling of user provided information is also of top importance.

## Source Code Auditing

Source code reviews are critical to understand the true state of our clients' applications. Removing the layers of abstraction and focusing on the raw application code allows us to obtain an unobstructed view of vulnerabilities, which could otherwise go undetected. Unlike black-box testing, which can be impeded by things like network equipment, security devices and services, rate limits, hard to find routes or inputs, code obfuscation and/or minimization and the fear of creating downtime, source code reviews reveal the true software quality. This gives our clients the confidence to deploy their software anywhere, knowing we've found the hidden vulnerabilities.

We pride ourselves on hiring engineers who not only break applications, but have experience building them as well. This differentiates Doyensec from many other consulting firms, as it allows us to immerse ourselves in the applications we test and create a more comprehensive threat model, ultimately revealing more impactful issues and in greater numbers.

Our methodology consists of several stages outlined in the table below. During this process, we typically begin by thoroughly reviewing the code to understand the composition of the application, its uses, data flows and its authentication and authorization structures. This provides the context needed to evaluate any potential bugs we might encounter in later steps.

Next, we use our custom threat model to trace inputs through the code and look for problem areas. These could be anything from typical bugs like injection style vulnerabilities and authorization bypasses, or subtle business-logic flaws and unsafe function usages, which are not as easily detected via automation. We also examine the frameworks used within the application to ensure they are configured as securely as possible for the given context.

Only once we really understand the application, will we deploy our custom scripts, created by our team over many years of experience. These parse the code and identify hotspots, where we have seen vulnerabilities manifested in the past. Our scripts typically identify coding errors and misconceptions about functionality during development and are the product of bespoke security research by our team.

Finally, we leverage a curated set of customized open-source tools to complete our analysis. We start with those specifically designed for the application's languages and components, eventually moving into more generalized tools. After assessing the application with these tools, we manually validate any findings they report and filter out the noise, delivering only actionable results to our clients

Asad Hansot, asad@codecontrolstudio.com - 2025-01-15T16:38:39.797Z

# About Doyensec

Doyensec was founded in 2017 by John and Luca who are its only stakeholders. The company exists to further the passion and focus of its creators. We aim to provide research-driven application security, enabling trust in our client's products and evolving the resilience of the digital ecosystem.

With offices in the US and Europe, Doyensec has access to a unique talent pool of security experts capable of providing worldwide consulting services.

We keep a small dedicated client base and expect to develop long term working relationships with the projects and people involved. We will find bugs, but we know that is just the first step in the process. At any stage of your security maturity, you can rely on Doyensec to solve your unique application security needs.

We value and rely on the following principles:

- **Passion**. We believe quality comes from passion and care. We love what we do, and continuously work on mastering our craft. Every engagement is finely executed with dedication and attention to details.

- **Expertise**. Our team has decades of experience in application security. We are industry leaders in penetration testing, reverse engineering, and source code review. Doyensec researchers have discovered numerous vulnerabilities in widely-deployed products, secured Fortune 500 enterprises, advised startups and worked with tech companies to eradicate security flaws.

- **Focus**. Security craftsmanship is all about individual attention and delivering tailored security services and products. We concentrate on application security and do fewer things, better.

- **Research**. The fast changing landscape of technologies and security threats requires constant innovation. We are dedicated to providing research-driven application security and therefore invest 25% of our time in building security testing tools, discovering new attack techniques and developing countermeasures.

Asad Mansoor, asad@anedcontrols.com, 2025-04-11T16:01:38.797Z